Don't Trust, Verify

Josh · Secure Sovereign

Published August 2, 2026 · Updated August 20, 2026

Coldcard, Credentialed Endorsement, and the Gap Between Source and Audit

Contents

The Bitcoin community has a handful of commandments. "Not your keys, not your coins." "Run your own node." "Don't trust, verify." Of these, **"don't trust, verify" is the one most directly about process.** It is repeated so often it has become the phrase that signals you are serious about Bitcoin, not just holding it.

Coldcard appropriated that commandment as a brand identity. "Don't Trust. Verify." was printed on the tamper-evident bag the device ships in. It was displayed on the device screen in Coinkite marketing copy. The four pillars on the Coinkite storefront: Bitcoin Only, Verifiable Source Code, Easy-to-use, Ultra-Secure. The tagline beneath the product: "Air-gapped signing options. Verifiable firmware." Reproducible builds. WalletScrutiny badge. **The entire commercial presentation was built around the idea that you don't have to trust Coinkite because you can verify everything yourself.** Verifiability was presented as the product.

Coldcard never commissioned an independent third-party security audit of its seed generation path. Not once across its entire commercial life. From March 2021 onward, Coldcard firmware was silently routing seed generation through a weak software PRNG instead of the hardware TRNG. The code was available. **The verification that Coinkite was marketing as its core proposition was absent from the most important property the device had.**

It has cost their audiences **$88 million** so far, and that number is still growing.

I. Three Errors That Compounded

The first error was **treating source-available as audited.** Coldcard's firmware was publicly readable under a restrictive license, not open source in any meaningful sense. The code could be read but not freely forked, redistributed, or built on commercially. Those are the conditions that generate active external scrutiny. **Source availability without that culture is not a security property.**

The second error was **treating workflow security as seed security.** Coldcard's post-seed security model is genuinely strong: dual secure elements, air-gapped PSBT signing, duress PINs, BIP-85. The promoters who evaluated these things evaluated them accurately. What nobody traced was the path from "user taps generate seed" to **which entropy source actually runs.** In retrospect this seems like the most elementary question you could ask about a device whose only job is to generate a secret. A seed that looks correct but was generated from insufficient entropy is not a secure seed. **Evaluating everything except whether the entropy was sound is like testing a safe by checking the paint.**

The third error was **treating social capital as technical verification.** When Adam Back calls something "super high assurance," the implied claim is that someone with standing to evaluate hardware security has evaluated it. When a Bitcoin Core contributor builds tooling that treats Coldcard as the only supported device, the implied claim is that the device passed whatever scrutiny a Core contributor would apply. When Unchained Capital integrates it and calls Coinkite "big fans," the implied claim is that institutional due diligence was performed. **None of those implied claims were verified about the seed generation path.**

For why reputation and credentialing substitute for verification in Bitcoin's development layer, see *The Social Layer Is the Attack Surface*.

II. How the Stack Built

The promotion didn't start with podcasters. **It started with tooling.**

HWI, the official Bitcoin Core-adjacent hardware wallet interface project, provides first-class Coldcard support via a dedicated module maintained by Ava Chow, a Bitcoin Core maintainer. Her own demo at London Bitcoin Devs in 2020: "I am going to be using a Coldcard because that is the easiest thing to do." James O'Beirne, Bitcoin Core contributor and author of OP_VAULT, built coldcore, a wallet tool whose README states Coldcard is "the only wallet supported at the moment because it is opensource, and supports air-gapped use via PSBT." O'Beirne's own framing reflects the community's conflation of source-available with open source. Craig Raw's Sparrow Wallet documentation includes a dedicated "Why Coldcard?" section recommending Coldcard directly.

A user following the most technically serious Bitcoin self-custody path, running their own node, using Bitcoin Core, following the tooling documentation, **arrived at Coldcard without encountering a single advertisement.** The default was structural, not simply marketing.

Then the educators confirmed what the tooling assumed. Then the institutions integrated what the educators confirmed. Then the vendor cited the institutions on the homepage. Coinkite's website stacked WalletScrutiny's "passed all 10 tests" badge next to BTC Sessions calling it "one of the most secure Bitcoin hardware wallets ever built" next to Bitcoin Verdict calling it "the most secure you can buy." **Each layer appears to have treated the layer below as diligence.** None of the layers included a seed-path audit.

From March 2021 onward, Coldcard was generating seeds from a far smaller entropy pool than anyone knew. Every influencer recommendation, every tutorial, every podcast episode, every institutional integration produced after that date was built on top of a device that had already failed the most fundamental test.

By July 2026, "Coldcard" and "most secure Bitcoin hardware wallet" were near-synonymous in serious self-custody discourse. **Disclosed sponsorship did not stop recommendations from functioning as trust signals.** "Don't trust, verify" had become trust the people who say "don't trust, verify."

III. The Review That Missed

The sharpest illustration is PortlandHODL's June 2022 public review.

Bitcoin Core contributor, AnchorWatch engineer. He publicly examined the Mk4's STM32 RNG driver and published his conclusion: "Looking through the source of the COLDCARD MK4 their driver implementation for the STM32 rng is correct."

He was right. The driver was correct. **The bug wasn't in the driver.**

The defect was in the build-time preprocessor guard in a different file, the guard that determined whether the driver was called at all. When `MICROPY_HW_ENABLE_RNG` is defined as zero (which it always was), the `#ifndef` check passes, the error never triggers, and seed generation falls through to MicroPython's Yasmarang software PRNG seeded from the chip's serial number and clock registers. The driver PortlandHODL reviewed was fine. **It just wasn't running.**

A credentialed Bitcoin Core contributor performed visible technical work. The community had reason to trust that work. The work stopped at the wrong file. The community's trust remained, and so did the vulnerability, for four more years.

This is the third error in practice. "Don't trust, verify" requires verifying the right thing. It is not satisfied by verifying something adjacent to the right thing and then extending trust to cover the gap.

IV. The Capital Layer

Ten31 led Coinkite's Series A in December 2024. Its managing partners, Matt Odell and Marty Bent, were already two of the most prominent Coldcard promoters in Bitcoin. **By the time they held equity, they had spent years recommending a wallet whose firmware was vulnerable.** The Series A added equity to a sponsorship relationship they had already been disclosing in public.

Rabbit Hole Recap, the weekly podcast co-hosted by Odell and Bent, routinely listed Coinkite in its standard sponsor block ("Shoutout to our sponsors: Coinkite") in published show notes, documented from at least July 2023 through July 2026. Odell's setup guide was listed directly on Coldcard's official documentation page, one of three educators whose guides Coinkite itself endorsed. Citadel Dispatch, Odell's separate audience-funded podcast, carried the Ten31 investment disclosure in the show notes of an episode featuring NVK. **The financial relationship was not hidden.** What was missing was not disclosure but verification: none of that sponsor or investment context included, or substituted for, an independent audit of the seed generation path.

The "don't trust, verify" standard applies to incentives as much as it applies to code. Disclosing a sponsorship or equity stake satisfies transparency about conflicts. It does not satisfy the verify step. An audience told to check the firmware could still treat a disclosed sponsor's recommendation as evidence the device had been scrutinized, when the scrutiny that mattered never happened.

One more data point on how thoroughly Coldcard's reputation was constructed: Zach Herbert, CEO of Foundation Devices and maker of Coldcard's closest competitor, published an open letter to NVK calling Coldcard "the most secure Bitcoin hardware wallet with the best security architecture..." A hardware wallet company CEO endorsing a competitor as the best in the market is about as strong a third-party validation as exists.

The irony runs deeper than that. Herbert built Foundation Devices' Passport on a fork of Coldcard's then-GPLv3 firmware, which was legally permitted under that license. GPL requires that anyone who forks and distributes must release their modifications under the same terms. NVK saw a competitor using his code exactly as the license allowed, publicly said he regretted releasing under GPL, and then Coinkite migrated to MIT plus Commons Clause. The Commons Clause addition is specifically designed to prevent commercial use, which is what Foundation Devices had done legally. The new license left the code source-visible but no longer open source by any standard definition. Coinkite began calling it "verifiable" rather than open source. Herbert and others publicly criticized the change.

The large 120-file commit that executed the license migration also rewrote the seed generation path. That rewrite is where the defective preprocessor guard was introduced. **The same period that produced the most credentialed endorsement Coldcard ever received also produced the code change that, five years later, allowed attackers to drain over $88 million from addresses likely tied to innocent Coldcard customers.**

V. What Verification Would Have Required

This is not a story about a sophisticated cryptographic attack or an exotic vulnerability class. **The defect was a configuration error.** Three files, one call chain.

An auditor asking "which entropy source actually runs when a user generates a seed?" would have read `shared/seed.py` to find the `generate_seed()` call, traced `ngu.random.bytes()` to the libngu guard in `external/libngu/ngu/random.c`, and checked the board configuration in `stm32/COLDCARD/mpconfigboard.h` where `MICROPY_HW_ENABLE_RNG` is set to zero. The guard uses `#ifndef`, which passes when the macro is defined to any value including zero. The hardware TRNG path is silently disabled. The fallback runs.

Findable. Not found by anyone in five years. **Found by an attacker, in the same public repository that the community had been citing as a reason to trust the device.**

VI. The Same System, Applied to Bitcoin Core

Here is the uncomfortable part.

Bitcoin Core was first released in January 2009. Its first independent third-party security audit was completed in September 2025, **sixteen years later**, and it was partial. In those sixteen years, the review process that was supposed to substitute for independent audit produced three notable visible failures.

An inflation bug was introduced in Bitcoin Core 0.14.0 in March 2017 as a performance optimization that skipped a block validation check considered redundant. The skipped check was not redundant. The bug allowed a miner to inflate Bitcoin's supply by spending the same inputs twice. It sat in production through multiple reviewed releases for roughly eighteen months before a developer outside Bitcoin Core discovered and disclosed it. It was never exploited on mainnet, but **the inflation bug in the software designed to enforce Bitcoin's 21 million cap passed review repeatedly before anyone found it.**

Bitcoin Core 30.0, shipped in late 2025, contained a wallet migration bug that under specific conditions deleted all wallet files in the user's wallet directory, with no recovery path if backups didn't exist. The dangerous code pattern, using `fs::remove_all()` on user wallet directories, was

introduced in 2022 and self-merged by Ava Chow. The PR itself received substantial review, but the specific lines containing the dangerous pattern received essentially none. In 2024, maintainer ryanofsky explicitly identified the exact risk in a code review, writing that the pattern "could wipe out a lot of other data," and recommended a followup PR to fix it. No followup was created. In 2025, an unrelated PR changed backup locations in a way that removed an earlier failure point that had been accidentally preventing the dangerous code from executing. The bug could now run. Users lost wallets. The fix arrived 18 days after the bug report. **A maintainer had named the precise failure mode a year earlier, recommended fixing it, and the warning was not acted on.**

Bitcoin Core 31.0, released April 2026, introduced a `-privatebroadcast` feature whose release notes stated explicitly: "Their IP address (and thus geolocation) is never known to the recipients." When the BIP324 v2 encrypted handshake failed, the software silently fell back to an unencrypted v1 retry that bypassed the Tor proxy entirely, exposing the sender's real IP address to the receiving peer. A malicious peer could deliberately trigger the handshake failure to force the exposure. The bug was disclosed June 6, 2026, six weeks after the feature shipped. It was fixed in 31.1.

Three failures, each defined by the gap between what the feature was supposed to do and what it actually did. A 21 million cap that could be increased. Wallets that got deleted. A private broadcast feature that wasn't private. **All three are the same class of failure as the Coldcard RNG defect:** a code path that ran when it shouldn't have, or didn't run when it should have, visible in the source, not caught by review. For why irreversible stakes and named-but-unfixed failures make a soft culture the wrong prescription, see *The Adversarial Default, §III*.

When the first independent audit finally arrived in September 2025, Quarkslab spent 100 man-days across three engineers over four months. The scope was limited to the P2P layer, mempool, block validation, and chain state. The published scope covered a minority of consensus-critical code paths, and libbitcoinkernel was explicitly excluded.

Many of the people who built Coldcard's reputation are the same people whose judgment you are supposed to trust on Bitcoin Core: **source availability treated as audit, contributor reputation treated as verification, institutional consensus treated as correctness.** Whether that mechanism has failed elsewhere is precisely the question that the "don't trust, verify" standard requires you to ask, and that social capital alone cannot answer. For refutations of judging Core on "technical merits alone" without a formal spec, see *Bitcoin Core: The Biggest Fallacies* (Fallacy 6). For the funding map, merge concentration, and documented adversarial cases in Core governance, see *Who Controls Bitcoin*.

VII. What Changes

The failures documented here are structural. **They will happen again anywhere reputation replaces verification.** The community preached a standard and didn't apply it to the things it trusted most.

The commandment is real. **The question is whether the community actually lives by it or just says it.**

Sources

- Galaxy Research on Coldcard losses (via The Block) — on-chain loss estimates cited in this article
- Coinkite, "Technical Deep Dive into the Entropy Issue" — firmware root cause
- Quarkslab, "Bitcoin Core Security Audit" — September 2025 P2P/mempool scope

Related: The Social Layer Is the Attack Surface, Who Controls Bitcoin, Bitcoin Core: The Biggest Fallacies.

This article is analytical commentary based on publicly available information. All factual claims are sourced from public records, public statements, and documented on-chain data. No malice or prior knowledge of the defect is attributed to any individual named. Dollar figures and victim counts reflect published on-chain estimates (e.g. Galaxy Research), not confirmed victim reports.

SECURESOVEREIGN

Markdown is the canonical source: https://secsov.com/articles/dont-trust-verify/index.md

Formatted snapshot of https://secsov.com/articles/dont-trust-verify

Josh · Secure Sovereign